讀書計畫（含研究方向）

顧晉瑋　靜宜大學資訊管理學系四年級｜預計民國 116 年 6 月畢業

權限規則修改後的存取控制迴歸測試：以零售營運原型為例

權限規則改過幾次之後，常會有錯誤沒人發現，例如某個角色多了一個動作，或被擋下的操作沒留紀錄。OWASP Top 10:2025 把存取控制失效排在第一位，也建議把存取控制寫進單元與整合測試 [3][4]。我打算先依門市作業，把現階段最需要核對的條件寫成一張預期表，每次修改就讓 CI 照表產生測試，看能不能比現有手寫測試多抓到植入的權限錯誤，以及 CI 會多花多少時間。

角色和權限的定義我參考 RBAC 標準 [1]。Martin 與 Xie 用植入錯誤評估權限測試 [2]，測的是 XACML 政策檔。我的原型把規則寫在 Python 裡，還要檢查再驗證和操作紀錄。

碩士班的安排

時間	修課與研究安排
一年級上	閱讀存取控制測試與植入錯誤的文獻，定下研究問題；先加強資料庫、研究方法和英文文獻閱讀；依開課修資通安全相關課程。實際開課以入學當年度為準。
一年級下	寫好預期表和測試產生程式並接進 CI，定義錯誤類型，小規模試做並檢查量測定義。
二年級上	執行植入錯誤實驗並和手寫測試比較。
二年級下	完成論文、口試與修訂；依研究成果及指導老師建議評估投稿。

預期表要寫的條件

條件	預計寫進預期表的內容
角色與帳號	檢視者、門市營運、管理者；未登入、正常和已停用的帳號。
動作與門市	要做的動作、目標單據或門市，以及帳號可操作的門市和主店。
數量與時段	補貨或調整的數量、門檻上下的邊界。非營業時間加風險標記，不單獨拒絕。補貨核准有風險標記（含高影響數量）會要求再驗證；庫存調整則在高影響數量時才要求。
再驗證狀態	還沒再驗證、仍在有效期內、已經過期。

每筆案例的預期結果分成允許、拒絕、要求再驗證三種，也寫明原因碼、資料會不會改變、該留哪些紀錄。答案依門市作業先寫好並凍結。下面是其中一組例子：

例：門市營運核准同店 500 件補貨

條件	預期結果
還沒完成再驗證	**要求再驗證**，單據不變
5 分鐘內已完成再驗證	**允許**，單據改為核准
換成檢視者，即使完成再驗證	**拒絕**，單據不變

原型目前設定的高影響門檻是 300 件，再驗證有效期是 5 分鐘。

研究做法

步驟	預計工作
1　寫好預期表	依工作任務整理上面的條件和每筆案例的預期結果，答案事先固定。
2　自動產生測試	

	由預期表展開成測試案例，授權判斷和實際寫入資料庫的流程都要測，接進 GitHub Actions，每次 push 執行。
3　植入權限錯誤	每次只改一處規則或程式，例如替檢視者加上核准補貨、把某個動作移出門市範圍檢查、跳過再驗證、讓拒絕路徑不寫紀錄；另外準備一組正確的修改。
4　比較與記錄	24 項手寫測試和新測試跑同一批修改，記錄抓到的錯誤、誤判次數與 CI 時間。

目前已經有的是原型、24　項測試和　CI。停用帳號、再驗證是否過期，現有測試還沒打到，會寫進預期表。預期表、測試產生程式和植入錯誤實驗要入學後才做。

衡量方式

指標	預計衡量方式
偵測率	被測試抓到的植入錯誤數／植入錯誤數，依錯誤類型分開呈現；改了程式但行為沒變的植入另外判斷，不列入計算。
誤報率	正確修改（例如新增合法動作並同步更新預期表）卻讓測試失敗的次數／正確修改總數。
結果正確性	允許、拒絕、要求再驗證三種結果分開看，也檢查原因碼，以及單據、庫存有沒有照預期改變。
紀錄完整性	應留紀錄的操作中、人員、時間、動作、門市、結果（拒絕時含原因）都齊全的比例。
CI 增加時間	相同環境下重複執行，比較加入新測試前後的執行時間，呈現中位數與第 95 百分位數。

錯誤類型會先從原型裡現有的規則挑，也就是角色權限表、門市範圍清單、再驗證清單和紀錄寫入。每一種都對每條規則逐一植入。原本那　24　項手寫測試是照既有案例寫的，所以結果會按類型列出兩邊各漏掉哪些。比較時，手寫測試會先補成涵蓋預期表的同一組條件，當作對照組。紀錄欄位和保護方式參考　OWASP　指引[5]。一開始先用合成資料，結論只講這個原型。

權限切得越細，越權的操作越難得逞，但正常工作被誤擋的機會、管理權限的負擔也可能跟著變高。這個取捨能不能用一組固定的測試案例量出來、操作紀錄要留哪些欄位才夠事後追查又不會多到沒人看，這兩題入學後再做。

畢業之後

畢業後我想先做資訊系統開發或維護，再做帳號與存取權限管理、系統安全維護。這兩年想把權限規則寫成能自動跑的測試：改程式時先核對。權限或程式一改，CI 照表跑一次，合併前就看得到改壞的地方。

初步參考資料

[1] Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., & Chandramouli, R. (2001). Proposed NIST standard for role-based access control. ACM Transactions on Information and System Security, 4(3), 224–274。
[2] Martin, E., & Xie, T. (2007). A fault model and mutation testing of access control policies. In Proceedings of the 16th International Conference on World Wide Web (pp. 667–676). ACM. doi: 10.1145/1242572.1242663。
[3] OWASP. (2025). A01:2025 Broken Access Control. OWASP Top 10:2025。
[4] OWASP. Authorization Cheat Sheet。
[5] OWASP. Logging Cheat Sheet。
[6] 逢甲大學。116 學年度碩士班甄試入學招生簡章，資通安全碩士學位學程分則。